

LAB 06

ShopNow - Siber Olay Sonrası GRC İncelemesi

Zorluk: Orta / İleri • Tahmini süre: 30-60 dakika • Rolünüz: GRC Incident Review Lead

1. HİKÂYE

Sektör E-ticaret	Ölçek 1.100 çalışan, 4 milyon müşteri
Olay 38.000 müşteri kaydının dışa aktarılması	Ortam AWS, CRM SaaS, veri ambarı, SOC hizmeti

ShopNow, müşteri destek platformundan olağandışı veri dışa aktarımı tespit etmiştir. Teknik ekip saldırganın ele geçirilmiş bir destek hesabını kullandığını belirlemiştir. Yönetim olayın teknik kök nedeninin 'phishing' olduğunu söyleyerek dosyayı kapatmak istemektedir. Denetim Komitesi ise yönetim, risk ve kontrol ortamının olaya nasıl katkıda bulunduğunu anlamak istemektedir. Siz bağımsız olay sonrası GRC incelemesini yönetiyorsunuz.

2. SİZE VERİLEN GÖREV

Saldırının teknik adımlarını yeniden üretmek yerine, olay öncesi kararları, kontrol sahipliğini, istisnaları, izlemeyi ve yönetim gözetimini değerlendirin.

3. OLAYLAR VE KANITLAR

E-01 | Olay zaman çizelgesi
02:14 başarısız oturumlar; 02:22 başarılı giriş; 02:31 toplu export; 03:05 SIEM alarmı; 05:40 SOC bildirimi; 09:10 hesap kapatma. SLA, kritik olayların 30 dakika içinde bildirilmesini gerektirir.

E-02 | MFA istisnası
Destek platformunda MFA altı ay önce devreye alınmıştır. Gece vardiyasındaki 42 taşeron hesap, eski çağrı merkezi yazılımıyla uyumluluk gerekçesiyle istisnadır. İstisna onayı üç ay süreli olmasına rağmen yenilenmemiştir.

E-03 | Erişim modeli
Destek temsilcileri tekil müşteri kaydı görüntüleyebilir. 'Supervisor' rolü toplu export yapabilir. Olaydaki kullanıcı supervisor rolünü iki yıl önce geçici görevde almıştır. Son access review'da yönetici hesabı uygun işaretlemiştir.

E-04 | Risk kaydı
Phishing riski 'orta' ve yıllık eğitimle işlenmiş görünür. Toplu veri dışa aktarımı ve taşeron erişimi ayrı senaryo olarak kayıtlı değildir. Yönetim KRI'ı yalnızca eğitim tamamlama oranıdır (%99).

LAB 06

ShopNow - Siber Olay Sonrası GRC İncelemesi

Zorluk: Orta / İleri • Tahmini süre: 30-60 dakika • Rolünüz: GRC Incident Review Lead

3. OLAYLAR VE KANITLAR - DEVAM

E-05 | SOC sözleşmesi

Kritik alarm bildirimi 30 dakikadır. Sağlayıcı, alarmın müşteriye özel use case listesinde 'orta' olarak sınıflandırıldığını belirtir. ShopNow aylık SOC hizmet raporlarını son dört ayda görüşmemiştir.

E-06 | DLP projesi

DLP bütçesi onaylanmış ancak veri ambarı göçü nedeniyle dokuz ay ertelenmiştir. Risk kabul kaydı yoktur. Güvenlik ekibi e-postayla 'mevcut loglama geçici olarak yeterli' görüşü vermiştir.

E-07 | Olumlu kanıt

Olay müdahale ekibi aynı gün hukuk, gizlilik ve iletişim ekiplerini toplamış; etkilenen kayıtları doğrulamış ve gerekli bildirim değerlendirmesini başlatmıştır. Toplantı ve karar kayıtları mevcuttur.

4. ÖĞRENCİNİN GÖREVLERİ

1. Olayı mümkün kılan yönetim ve kontrol koşullarını ilişkilendirin.
2. Teknik kök neden ile kurumsal kök nedenleri ayırın.
3. MFA istisnası, access review ve SOC gözetimini değerlendirin.
4. Yönetimin mevcut KRI setinin yeterliliğini tartışın.
5. Olumlu çalışan kontrolleri de raporunuza dahil edin.
6. DLP erteleme sürecini risk kabul süreci açısından değerlendirin.
7. Denetim Komitesine üç öncelikli iyileştirme sunun.

5. TESLİM EDİLMESİ BEKLENEN ÇIKTI

- Olay sonrası kontrol haritası
- Kök neden analizi
- 3-5 denetim gözlemi
- Önceliklendirilmiş aksiyon planı
- Yönetim Komitesi özeti

ÇALIŞMANIZI TAMAMLADINIZ MI?

Bu vaka çalışmasının tek bir doğru cevabı olmayabilir. Önemli olan; riskleri nasıl değerlendirdiğiniz, kanıtları nasıl yorumladığınız ve vardığınız sonucu nasıl savunduğunuzdur.

Çalışmanızı tamamladıktan sonra çıktınızı:

volkan@grcustasi.com

adresine gönderebilirsiniz.

Gönderdiğiniz çalışmayı inceleyerek size geri dönüş sağlayacağım.

- Volkan Güler, CISA, CISM
GRC Ustası